

[LOGO AREA]

AMMAR ALZAIEM

CYBERSECURITY | VAPT

SECURITY ASSESSMENT REPORT

Dha Marketplace Assessment – Task 4

REPORT ID	AZ-WEB-2026-004
VERSION	1.0
ASSESSMENT DATE	10/9/2026 - 16/9/2026
REPORT DATE	19/9/2026
PREPARED BY	Ammar Alzaiem
CLASSIFICATION	Internal

Objective

A vulnerability assessment was conducted on the target website, With the use of Nmap, WhatWeb, Gobuster, Burp Suite and SSLyze. Each tool scanned and enumerated its respective area. From the results, I attempted to identify any security weakness or hardening recommendations. The report goes as follows

Target:

<https://dhamarketplace.com>

Scope of Work

Only a list of tools were authorized to use, Any scanning or probing was done only on the provided target, Any discovered vulnerabilities or weakness or misconfigurations were only reported and not exploited in any way.

Tool's Findings

1.Nmap

First I made sure the target is online with the **-sn** option.

```
(ammar@noOne)-[~]
$ nmap -sn dhamarketplace.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-10 23:11 +03
Nmap scan report for dhamarketplace.com (54.197.178.48)
Host is up (0.066s latency).
Other addresses for dhamarketplace.com (not scanned): 52.44.68.194
rDNS record for 54.197.178.48: ec2-54-197-178-48.compute-1.amazonaws.com
Nmap done: 1 IP address (1 host up) scanned in 6.81 seconds
```

The host is online, let's now scan for any running services on ports.

```
(ammar@noOne)-[~]
$ nmap dhamarketplace.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-10 23:13 +03
Nmap scan report for dhamarketplace.com (52.44.68.194)
Host is up (0.068s latency).
Other addresses for dhamarketplace.com (not scanned): 54.197.178.48
rDNS record for 52.44.68.194: ec2-52-44-68-194.compute-1.amazonaws.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 12.99 seconds
```

From the output above we can see there's two services running on the target. http, https, on 80,443 ports respectively. Let's prob for the services version running behind these services and an OS version.

```
(ammar@noOne)-[~]
$ nmap -sV -O -p 80,443 dhamarketplace.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-10 23:16 +03
Nmap scan report for dhamarketplace.com (52.44.68.194)
Host is up (0.082s latency).
Other addresses for dhamarketplace.com (not scanned): 54.197.178.48
rDNS record for 52.44.68.194: ec2-52-44-68-194.compute-1.amazonaws.com

PORT      STATE SERVICE VERSION
80/tcp    open  http      Golang net/http server
443/tcp    open  ssl/http  nginx (bad gateway)
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_
SF-Port80-TCP:V=7.95%I=7%D=9/10%Time=6AA31023%P=x86_64-pc-linux-gnu%r(GetR
SF:request,4B,"HTTP/1.0\x20200\x200K\r\nDate:\x20Thu,\x2010\x20Sep\x202026
SF:\x2020:16:35\x20GMT\r\nContent-Length:\x200\r\n\r\n")%r(HTTPOptions,4B,
SF:"HTTP/1.0\x20200\x200K\r\nDate:\x20Thu,\x2010\x20Sep\x202026\x2020:16:
SF:35\x20GMT\r\nContent-Length:\x200\r\n\r\n")%r(RTSPRequest,67,"HTTP/1.1
SF:\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf
SF:f-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(FourOhFour
SF:Request,4B,"HTTP/1.0\x20200\x200K\r\nDate:\x20Thu,\x2010\x20Sep\x20202
SF:6\x2020:16:37\x20GMT\r\nContent-Length:\x200\r\n\r\n")%r(GenericLines,6
SF:7,"HTTP/1.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x
SF:20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%
SF:r(Help,67,"HTTP/1.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/
SF:plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Re
SF:quest")%r(SSLSessionReq,67,"HTTP/1.1\x20400\x20Bad\x20Request\r\nConte
SF:nt-Type:\x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\
SF:n400\x20Bad\x20Request")%r(LPDString,67,"HTTP/1.1\x20400\x20Bad\x20Req
SF:uest\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nConnection:\x2
SF:0close\r\n\r\n400\x20Bad\x20Request")%r(SIPOptions,67,"HTTP/1.1\x20400
SF:\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\n
SF:Connection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(Socks5,67,"HTTP/1
SF:.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset
SF:=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(OfficeS
SF:can,A3,"HTTP/1.1\x20400\x20Bad\x20Request:\x20missing\x20required\x20H
SF:ost\x20header\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nConne
SF:ction:\x20close\r\n\r\n400\x20Bad\x20Request:\x20missing\x20required\x2
SF:0Host\x20header");
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
No OS matches for host

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.97 seconds
```

- ▶ There's two web services running:
 - Port 80(HTTP): running Golan net/http server.
 - Port 443(HTTPs): running nginx, but it throws a 502 Bad Gateway error, This indicate that nginx is working as a reverse proxy. But cannot communicate with the application server behind him.
- ▶ The OS detection failed: because nmap requires one open and one closed port to fingerprint the operating system version.
- ▶ Reverse DNS indicate the target is hosted on AWS service.

2.WhatWeb

This tool automates fingerprinting websites, identify the software and technologies running behind them.

The output identified several things.

1. Technology Stack
 - Front-End & Back-End: Application Framework Next.js
 - Web Server: Nginx 1.28.1
 - Hosting: Amazon Web Services (AWS)
2. HTTP Security Headers
 - **X-Content-Type-Options: nosniff:** Helps prevent MIME-type sniffing.
 - **X-Frame-Options: DENY:** Prevents the website from being loaded inside frames, which prevents click-jacking
 - **Referrer-Policy: strict-origin-when-cross-origin:** Limits information included in the Referer header when navigating between origins.
 - **Permissions-Policy:** Disables access to the geolocation, microphone, and camera.
 - **X-XSS-Protection: 1; mode=block:** An old browser XSS protection mechanism
3. And some other information:
 1. Email: info@dhamarketplace.com
 2. Meta Generator: GIS PLUS
 3. Open Graph Detected

3.Gobuster

Gobuster enumerated a bunch of directories hosted on the target,

```
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: https://dhamarketplace.com/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-1.0.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/health (Status: 200) [Size: 2]
/contact (Status: 200) [Size: 42747]
/faqs (Status: 200) [Size: 77537]
/gallery (Status: 200) [Size: 71092]
/admin (Status: 200) [Size: 18694]
/profile (Status: 200) [Size: 18004]
/register (Status: 200) [Size: 18538]
/marketing (Status: 200) [Size: 20089]
Progress: 4782 / 141709 (3.37%)[ERROR] Get "https://dhamarketplace.com/bobbyandnihal": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
/dashboard (Status: 200) [Size: 19099]
/login (Status: 200) [Size: 18019]
/affiliates (Status: 200) [Size: 18491]
/launch (Status: 200) [Size: 19126]
/advertise (Status: 200) [Size: 17204]
/properties (Status: 200) [Size: 26929]
/forgot-password (Status: 200) [Size: 36291]
Progress: 101650 / 141709 (71.73%)[ERROR] Get "https://dhamarketplace.com/2001-11161_53-0": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Progress: 118644 / 141709 (83.72%)[ERROR] Get "https://dhamarketplace.com/gif_webroot_spysweeper": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Progress: 130975 / 141709 (92.43%)[ERROR] context deadline exceeded (Client.Timeout or context cancellation while reading body)
Progress: 131919 / 141709 (93.09%)[ERROR] context deadline exceeded (Client.Timeout or context cancellation while reading body)
Progress: 139124 / 141709 (98.18%)[ERROR] Get "https://dhamarketplace.com/what-is-csharp": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Progress: 141708 / 141709 (100.00%)

Finished
```

The following endpoints returned HTTP 200:

/health	/contact	/faqs	/gallery	/admin
/profile	/register	/marketing	/dashboard	/login
/affiliates	/launch	/advertise	/properties	/forgot-password

The administrative endpoint(/admin) seems to be accessed without authentication. This will be investigated manually with burp suite.

4.SSLyze

SSLyze analyzed the TLS configuration and certificate. Overall the configuration is strong:

- Protocols: SSL 2.0/3.0 and TLS 1.0/1.1 are rejected. Only TLS 1.2 and TLS 1.3 are accepted, which is good
- Certificate: issued by Amazon RSA 2048 M01, RSA-2048 / SHA-256, valid 03/06/2026 – 17/12/2026, trusted by all major stores; wildcard SAN *.dhamarketplace.com.

5.Burp Suite

Burp was used to confirm what the automated tools reported and to inspect raw requests and responses directly.

- <http://dhamarketplace.com/> returns 301 to <https://dhamarketplace.com/>, The redirect itself travels over cleartext(Finding 1).
- X-Frame-Options, X-Content-Type-Options and Referrer-Policy each emitted twice, once by Next.js, once by nginx(Finding 2).

Manual endpoint checks

I tended not to rely on the Gobuster results alone, important endpoints were examined manually through burp:

1. **robots.txt**: Returned 200, It discloses disallowed paths(Finding 5).
2. **/admin**: When the /admin directory is requested, the page calls api/auth to check if the session is authenticated if not, it redirects unauthenticated users to /login. This is called false positive, it was identified by Gobuster, that's why you can't trust tools results blindly you have to check yourself.
3. **/api**: requesting this directory returns 404(not found) status code.
4. **/sitemap.xml**: also can be accessed.

Findings Summary Table

Findings	Severity	Confidence	Status
Missing HTTP Strict-Transport-Security (HSTS) header	Medium	Confirmed	Open
Missing Content-Security-Policy (CSP) header	Medium	Confirmed	Open
Web server & framework version disclosure	Low	Confirmed	Open
Duplicate / conflicting security response headers	Low	Confirmed	Open
Sensitive Endpoint Disclosure via robots.txt	Low	Confirmed	Open

Finding 1 — Missing HTTP Strict-Transport-Security (HSTS)

Severity: Medium

Description: HSTS (HTTP Strict Transport Security) is a response header that tells the browser "always use HTTPS for this site, never plain HTTP." The site is missing it. When I browsed the site through Burp, the HTTPS responses had no Strict-Transport-Security header. The site does redirect http:// to https:// (a 301), which is good, but that redirect happens over plain HTTP first. Means the initial cleartext request can be intercepted and downgraded (SSL-strip / MITM).

Evidence: No Strict-Transport-Security header in responses to GET /, /login, /robots.txt.

Remediation: Add this header at the load balancer or web server.

The screenshot displays the Burp Suite Professional interface. The 'HTTP History' tab is active, showing a list of intercepted requests. The selected request is from 'https://dhammarketplace.com' to '/login', with a status code of 200 and a MIME type of 'text/html'. The 'Response' tab is open, showing the raw HTTP response. The response includes headers such as 'Date: Sun, 13 Sep 2023 19:15:05 GMT', 'Content-Type: text/html; charset=utf-8', 'Server: nginx/1.20.1', 'X-Content-Type-Options: nosniff', 'X-Frame-Options: DENY', 'X-Nextjs-Cache: HIT', 'X-Nextjs-Prerender: 1', 'X-Nextjs-Prerender: 1', 'X-Nextjs-Stale-Time: 300', 'X-Powered-By: Next.js', 'Cache-Control: s-maxage=31536000', 'Etag: "gloY7m1t3dy"', 'X-Frame-Options: DENY', 'X-Content-Type-Options: nosniff', 'X-Xss-Protection: 1; mode=block', 'Referrer-Policy: strict-origin-when-cross-origin', and 'Permissions-Policy: geolocation(), microphone(), camera()'. The response body is rendered as HTML, showing a login form with fields for 'email' and 'password'.

Finding 2 — Missing Content-Security-Policy (CSP)

Severity: Low–Medium

Description: Content-Security-Policy is a header that tells the browser exactly which sources (scripts, styles, images) it's allowed to load. It's one of the strongest defenses against XSS.

Evidence: No Content-Security-Policy header on any observed response.

Remediation: Roll out a CSP. Start with Content-Security-Policy-Report-Only so you can watch what it would block without breaking the site, then switch it to enforcing mode.

The screenshot displays the Burp Suite Professional interface. The 'HTTP history' tab is active, showing a list of intercepted requests. The selected request is a GET request to `https://dhammarketplace.com/dashboard` with a status code of 200. The 'Response' tab is open, showing the raw response content. The response headers include:

- `Date: Sun, 13 Sep 2026 19:24:46 GMT`
- `Content-Type: text/html; charset=utf-8`
- `Server: nginx/1.28.1`
- `X-Content-Type-Options: nosniff`
- `X-Frame-Options: DENY`
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Vary: rsc, next-router-state-tree, next-router-prefetch, Accept-Encoding`
- `X-Nextjs-Cache: HIT`
- `X-Nextjs-Prerender: 1`
- `X-Nextjs-Prerender: 1`
- `X-Nextjs-Stale-Time: 300`
- `X-Powered-By: Next.js`
- `Cache-Control: s-maxage=31536000`
- `Etag: "23nsgv5ueqj1"`
- `X-Frame-Options: DENY`
- `X-Content-Type-Options: nosniff`
- `X-XSS-Protection: 1; mode=block`
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Permissions-Policy: geolocation(), microphone(), camera()`

The response body shows the HTML structure of the dashboard page, including a meta tag for the viewport and a script tag for the Next.js framework.

Finding 3 — Server / Technology Version Disclosure

Severity: Low

Description: Responses reveal the exact technology stack, aiding targeted attacks:

- Server: nginx/1.28.1
- X-Powered-By: Next.js
- x-nextjs-cache / x-nextjs-prerender / x-nextjs-stale-time framework headers.

Evidence: Response headers on GET /.

Remediation: Hide the version details. In nginx set `server_tokens` off, remove the X-Powered-By header, and strip the x-nextjs-(cache, prerender, stale-time) headers.

This screenshot is similar to the one above, showing the Burp Suite Professional interface. The 'HTTP history' tab is active, and the selected request is a GET request to `https://dhammarketplace.com/dashboard` with a status code of 200. The 'Response' tab is open, showing the raw response content. The response headers include:

- `Date: Sun, 13 Sep 2026 19:24:46 GMT`
- `Content-Type: text/html; charset=utf-8`
- `Server: nginx/1.28.1`
- `X-Content-Type-Options: nosniff`
- `X-Frame-Options: DENY`
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Vary: rsc, next-router-state-tree, next-router-prefetch, Accept-Encoding`
- `X-Nextjs-Cache: HIT`
- `X-Nextjs-Prerender: 1`
- `X-Nextjs-Prerender: 1`
- `X-Nextjs-Stale-Time: 300`
- `X-Powered-By: Next.js`
- `Cache-Control: s-maxage=31536000`
- `Etag: "23nsgv5ueqj1"`
- `X-Frame-Options: DENY`
- `X-Content-Type-Options: nosniff`
- `X-XSS-Protection: 1; mode=block`
- `Referrer-Policy: strict-origin-when-cross-origin`
- `Permissions-Policy: geolocation(), microphone(), camera()`

The response body shows the HTML structure of the dashboard page, including a meta tag for the viewport and a script tag for the Next.js framework.

Finding 4 — Some Security Headers Are Sent Twice

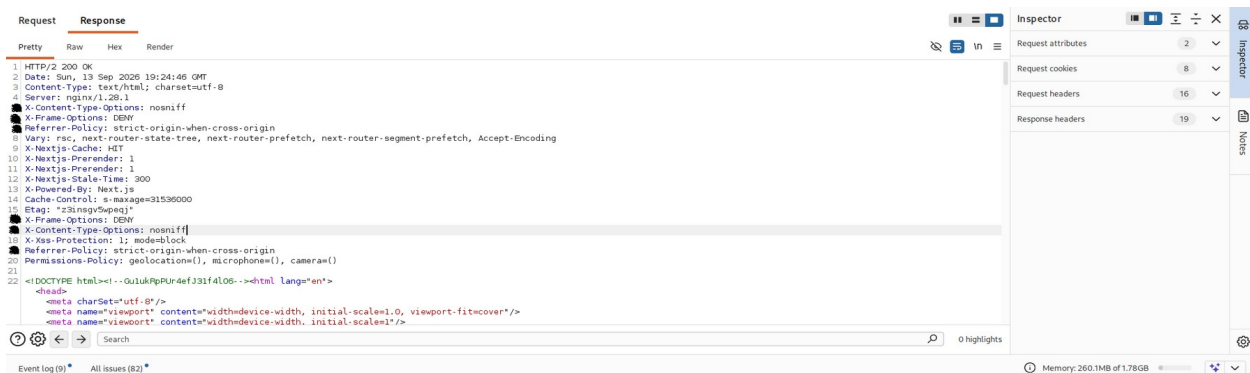
Severity: Informational

Description: A configuration issue.

- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy

each show up twice in the response. once added by the Next.js app and once by nginx.

Remediation: Set each security header in one place only.



Finding 5 — Disclosure Via Robots.txt

Severity: Low

Description: is publicly readable by design and is a crawler directive. A Disallow entry does not restrict access to a path, it only publishes that the path exists. The file discloses twelve disallowed paths

/admin	/buyer	seller/dashboard
/dashboard	/profile	/update-profile
/change-password	/security-approval	/property-approval
/building-record-approval	/campaign-approvals	/api

Worth comparing against gobuster, its scan ran against a wordlist and did not find eight of these paths.

Remediation: Remove the Disallow block from robots.txt and keep only public paths. To keep these pages out of search results without publishing their names, use an X-Robots-Tag: noindex response header or a <meta name="robots" content="noindex"> tag on the pages themselves.

```
User-Agent: *
Allow: /
Allow: /properties
Allow: /properties/
Allow: /realtor-profile/
Allow: /contact
Allow: /faqs
Allow: /gallery
Allow: /advertise
Allow: /how-to-use
Allow: /bidding-rules
Allow: /register
Allow: /login
Allow: /upcoming-features/events/
Allow: /architect-profile/
Allow: /solar-firm-profile/
Allow: /geotechnical-firm-profile/
Allow: /structural-engineer-profile/
Allow: /vetting-engineer-profile/
Allow: /vendor-profile/
Disallow: /admin
Disallow: /buyer
Disallow: /seller/dashboard
Disallow: /dashboard
Disallow: /profile
Disallow: /update-profile
Disallow: /change-password
Disallow: /security-approval
Disallow: /property-approval
Disallow: /building-record-approval
Disallow: /campaign-approvals
Disallow: /api

Sitemap: https://dhamarketplace.com/sitemap.xml
```

What did I learn

You can't always depend on automated tools and scans, you have to manually check on important findings to avoid false positives, I viewed a practical example of where a downgrading(SSL Strip) a website process can happen

Conclusion

The vulnerability assessment of dhamarketplace.com found a well-configured, modern web application with a strong TLS setup and several security headers already in place. No critical or high risk issues were identified within the passive scope. To improve security posture, add the HSTS and CSP headers, and reduce information disclosure (version banners).